ELMS-009 — Directory Listing Enabled (Apache Autoindex)

Attribute	Detail
Finding ID	ELMS-009
Severity	Low
CVSS 4.0	4.3 — CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N
OWASP 2021	A05 — Security Misconfiguration
CWE	CWE-548, CWE-200
Affected component	http://localhost/elms/includes/ (and other non-index directories)
Parameter	None (server configuration)
Auth context	None
Status	Confirmed

Description & Root Cause

Apache `Options +Indexes` (autoindex) is enabled, so directories without an index file return a browsable listing of their contents. `/elms/includes/` is served as a clickable file index, exposing source includes (including `config.php`) and easing discovery of other sensitive artifacts (e.g. the `elmsdb.sql` dump, ELMS-003). Root cause: default-permissive directory indexing left enabled in the deployed vhost.

Business Impact

Information disclosure and reconnaissance aid: an anonymous attacker enumerates server-side file names and locations without guessing, directly simplifying ELMS-003 (locate the DB dump) and source-informed attacks.

Proof of Concept — Step by Step

Step 1 — Request a directory with no index file. `GET /elms/includes/` returns HTTP 200 with an Apache-generated "Index of /elms/includes" listing.

Step 2 — Enumerate. The listing reveals include file names (incl. `config.php`) and modification times.

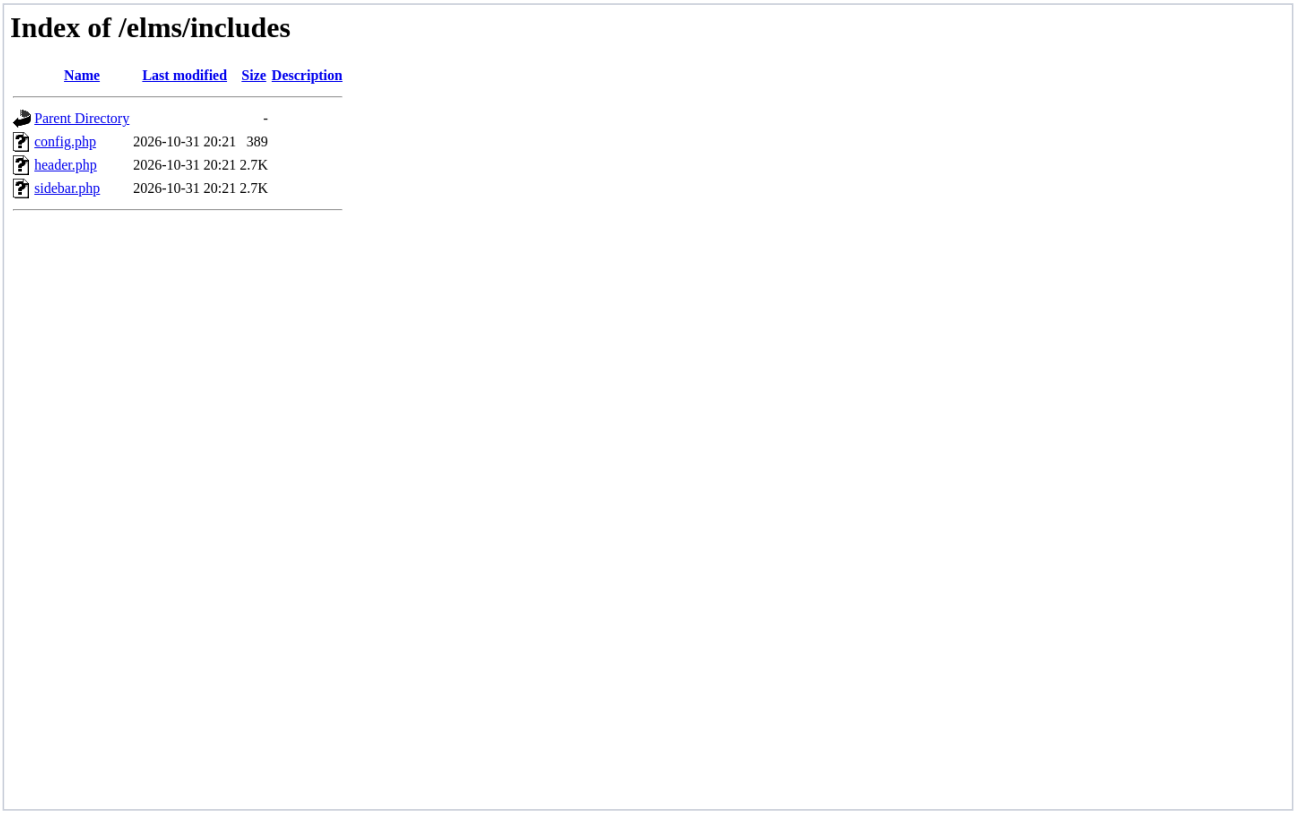

Figure 1 — Apache autoindex of /elms/includes/ rendered live: the directory is fully browsable to an unauthenticated visitor, exposing server-side include files (including config.php). Red-box focus: the "Index of /elms/includes" heading and the clickable file entries.

Exploit payload:

```
curl -s http://localhost/elms/includes/        # returns the autoindex HTML listing
```

HTTP Evidence

Capture `evidence/responses/08_dirlist.resp`: HTTP 200 with the Apache autoindex body; sealed event note "Apache autoindex enabled".

Remediation

Disable directory indexing globally and rely on explicit routing:

```
Options -Indexes
```

Place an `index.html` / `index.php` in any directory that must exist under the web root, and move non-public includes outside the document root entirely.

Re-test Procedure

Request `/elms/includes/` (and other directories) -> expect HTTP 403 (or a 404/empty index), with no file listing returned.

Exploitation Feasibility

Trivial browsing; impact is reconnaissance.

Existing CVE Verification

No CVE (configuration). Status: **No matching CVE identified**.

References

- OWASP WSTG-CONF-04/-05; CWE-548.

Conclusion

Confirmed directory listing on `includes/` and `assets/`. Low severity; disable autoindex and restrict sensitive files.